Roles, Access & Deleted Items — v0.4.0

ADT Dental Clinic Cashflow · released 2026-11-10

This note lists what was built for the "permission, access and role" request, point by point, the rules behind it, where to find each change, what you must run, how it was tested, and what you may want to decide next.

What was updated, by requested point

#	Requested point	What was done	Where
1	An update structure for permission, access and role, similar to the screenshot	**Users → Manage** opens a screen titled *Update staff details and clinics* with three tabs: **Personal Information** (name, e-mail), **Access & Permissions** (role, **Authorized clinics** checkboxes, grouped **System privileges** checkboxes) and **Account Settings** (reset password, remove account).	Users → Manage
2	Easier to manage permission / access per user	Each role gives default ticks; every privilege can be switched on or off **for one person**. Only the differences are stored, marked *extra* / *removed*, with **Reset to role defaults**. Several clinics can be ticked per person (first = home clinic). The Users list shows role, clinics and a "customized" tag.	Access & Permissions tab
3	Add **owner** and **superuser** to the role list	**Owner** is a new role (above admin; several allowed). **Superuser** stays the top role. Only the superuser can create or change an owner.	Users → Add a user / Manage
4	Admin / owner have similar controls and access	Owner and admin have identical default privileges and both work in every clinic. The one difference: an owner can also manage and reset admins; an admin cannot touch owners or other admins.	Users
5	Owner / admin can only **soft delete**; the superuser can revert	Deleting a visit, procedure line, payment, expense or attached file moves it to **Deleted items** instead of destroying it. It disappears from every list and report. Only the superuser opens that page, with **Restore** and **Delete permanently**.	Deleted items (superuser menu)
6	Remove the superuser from the users list	The superuser is never listed, for anyone, including themselves. Nobody can change or remove that account from the app.	Users

Roles

Role	Who	Works in	Can manage
Superuser	The developer / top owner account	Every clinic	Everyone, including owners. Only one who sees Deleted items.
Owner	Clinic owners (several allowed)	Every clinic	Admins, dentists, staff
Admin	Branch / office administrators	Every clinic	Dentists, staff
Dentist	Clinicians	Clinics ticked for them	Nobody
Staff	Front desk, assistants	Clinics ticked for them	Nobody

Rules enforced on the server (not just on the screen): nobody changes their own access; nobody manages someone at their level or above (except the superuser); you can only give a role you are allowed to give; you can only switch **on** a privilege you hold yourself.

Default privileges by role

The superuser always holds every privilege. A ✔ is the starting tick; any of them can be changed per person.

Group	Privilege	Owner	Admin	Dentist	Staff
Visits & Queue	Add visits and check patients in	✔	✔	✔	✔
Visits & Queue	Edit visits that are not Cleared yet	✔	✔	✔	✔
Visits & Queue	Edit visits that are already Cleared	✔	✔		✔
Visits & Queue	Move a visit back or skip a step	✔	✔		
Visits & Queue	Delete visits and transaction lines	✔	✔		
Visits & Queue	Import transactions from a CSV file	✔	✔		
Payments & Files	Record a payment	✔	✔	✔	✔
Payments & Files	Remove a payment	✔	✔		
Payments & Files	Attach photos and files	✔	✔	✔	✔
Payments & Files	Remove attached files	✔	✔		
Patients	Merge duplicate patients	✔	✔		
Patients	See PWD / Senior ID numbers in full	✔	✔		
Expenses	Add expenses	✔	✔	✔	✔
Expenses	Correct expenses	✔	✔		
Expenses	Delete expenses	✔	✔		
Reports	Commission report and downloads	✔	✔		
Reports	Audit trail (edit history)	✔	✔		
Reports	Void an HMO billing	✔	✔		
Reports	See everyone's performance	✔	✔		
Rates & Targets	Edit the price list and procedures	✔	✔		
Rates & Targets	Edit commission rates and tiers	✔	✔		
Rates & Targets	Edit sales targets	✔	✔		
Administration	Manage users, roles and access	✔	✔		
Administration	Manage clinics (branches)	✔	✔		

Clinics

- **Owners and admins** work in every clinic and can pick or move the clinic of a visit.
- **Dentists and staff** work in the clinics ticked for them. One clinic: every visit is saved under it. Several: they choose among those only. A visit is never saved under a clinic they are not ticked for (checked on the server).
- The **Queue, Day end, HMO billing and Overview** show only a person's own clinics, starting at their home clinic. There is no "All clinics" option for them.
- A dentist or staff member with **no clinic ticked** cannot add visits.
- The SQL gives everybody the clinic they have today, so nothing changes until you tick more.

Deleted items (soft delete)

What is deleted	What is kept	Restore brings back
A visit	Visit, all its procedure lines, payments, attached files, status history	All of it, identical (ids, amounts, dates, commission)
One procedure line	The line (and any payment tied to it). The **last** line of a visit takes the whole visit	The line / the whole visit
A payment	The payment and its proof files	Both
An expense	The expense and its receipts	Both
An attached file	The file itself	The file

How it behaves:

- The copy is written **first**; if it fails, nothing is deleted.
- Deleted items are removed from the live tables, so no report, total, commission or Day end counts them.
- Restore checks first: the record is not already there, the visit / expense / payment it belongs to still exists (otherwise: "Restore the visit first"), and a reused invoice number is flagged with a **Restore anyway** option. If a step fails it undoes itself, so you never get half a visit.
- A restore is written to the audit trail ("Visit restored").
- Before the new SQL is run, deleting is **switched off** with a clear message, so nothing can be lost.
- Not covered (not asked): patients, procedures, users, branches. Those work as before.

What you need to run

1. In the Neon SQL Editor run `scripts/sql/2026-11-roles-permissions-trash.sql` **before** starting this version. Run **STEP 1** (adds the `owner` role) on its own and wait for success, then **STEP 2** (three new tables). Safe to repeat.
2. Still pending from earlier updates, in this order, if not yet done: `2026-11-hmo-billings.sql`, `2026-11-line-loa.sql`, `2026-11-commission-tier-sheet-sync.sql`, `2026-11-commission-transfer-split.sql`.
3. To make someone an owner: sign in as the superuser → Users → Add a user (role Owner), or Manage an existing person and change their role to Owner.

Behavior changes to know about

- **CSV import** is now owner/admin only by default (it can be ticked for anyone).
- **Deleting** by owners and admins is no longer permanent; only the superuser can purge.
- **Dentists/staff with several clinics** start on their home clinic in Overview and Queue.
- The **superuser row is hidden** on the Users screen.
- Changes to access apply on the person's **next page load** (no sign-out needed).

How it was tested

On a copy of the database (never your live data):

- **100+ automated checks** (`scripts/test-roles-permissions.ts`): the privilege catalog and role defaults; override round-trips; who may manage / reset whom; assignable roles; clinic rules (one, several, none, admin) for visits, Queue and Day end; saving access in the database (only differences

stored, clinics, promotion to admin / owner); and soft delete + restore of **every kind** (visit with payment and file, line, last line, payment with proof, file, expense with receipt), including: totals drop to zero after delete, byte-for-byte file restore, real dates restored, refused restore when the visit is missing or already restored, invoice-number clash and forced restore, and purge.
- **Browser walk-through** with test accounts: an owner cannot see the superuser, cannot make an owner, has no Deleted items link and is bounced from it; opened Manage on a staff member, ticked a privilege, saved, reloaded (persisted, "extra" shown), reset to defaults; a staff member cannot open Users; the superuser sees Deleted items and can create an owner; an owner deleted a visit (gone from the list) and the superuser restored it (back in the list).
- The HMO billing and commission-transfer checks from earlier versions still pass.
- Type check and lint are clean.

Files changed

- Database: `scripts/sql/2026-11-roles-permissions-trash.sql`, `src/lib/db/schema.ts`.
- Rules: `src/lib/auth/permissions.ts`, `guards.ts`, `branch-policy.ts`, `reset-rules.ts`, `src/lib/cashflow/user-schema.ts`, `audit-types.ts`.
- Data: `src/lib/db/user-access.ts`, `deleted-items.ts` (new); `users.ts`, `invoices.ts`, `transactions.ts`, `payments.ts`, `expenses.ts`, `attachments.ts`, `day-end.ts`, `hmo-billing.ts`.
- Screens: `users/page.tsx`, `users/[id]/page.tsx`, `user-access-editor.tsx`, `users-manager.tsx`, `password-dialog.tsx`, `trash/page.tsx`, `deleted-items-list.tsx`, `capabilities-context.tsx`, navigation, layout, and the visit, payment, file, expense, patient, queue, day end, HMO, commission, performance and overview pages.
- Release: `version.ts`, `package.json` (0.4.0), `CHANGELOG.md`, Help page.

What you may have missed, and suggestions

Please decide / check

1. **Who becomes Owner?** Today's admins stay admins. Decide who should be an owner (they can then manage the admins). Only you, as superuser, can promote.
2. **Review the role defaults** in the table above. Two worth a look: staff may edit already-Cleared visits (as before); CSV import is now owner/admin only.
3. **Tick clinics** for every dentist and staff member who works in more than one branch (Users → Manage → Access & Permissions).
4. **Reading is not yet limited by clinic** in the Transactions and Patients lists: a dentist or staff member can still see them for every clinic. Adding visits, the Queue, Day end, HMO billing and Overview are limited. If you want the lists limited too, say so; it is a small, separate change.
5. **Rotate the Neon password and `AUTH_SECRET`** (still open from earlier) and commit/push the uncommitted files.

Suggestions

- **A count badge on "Deleted items"** in the menu, so you notice a deletion without opening it, and a daily e-mail digest of what owners/admins deleted.
- **Keep deleted items for a set time** (for example 90 days) and then purge, because deleted photos are stored in the database and take space.
- **Soft delete for patients** (merge/remove) if you want the same safety net.

- **Two-step sign-in** for the superuser and owners, since they hold the most power.
- **An access-change report**: access changes are written to the audit trail; a small "who has what" page (everyone with extra privileges) would make periodic reviews quick.
- If you ever need an admin limited to one branch, that would be a new "clinic admin" idea built on the same ticks.

Not changed

- The set of 24 privileges is fixed in code (adding one is a small developer change).
- A person has one role; privileges are the only per-person adjustment.
- Open items from earlier: per-HMO totals on Day end, 19 price-list procedures on neither sheet, HMO 10% extension to PF/TF/Simple extraction, Perez override removal, Dayandante tier, prices/VAT for 10 new procedures, default commission %.